CRA Incident Simulation

Çıktı: Incident Workflow

Ad Soyad: _____ Grup: _____ Tarih: _____

Kavram: Bir olayda en değerli iki şey zaman ve kanıttır. CRA'nın 24s / 72s / 14 gün yükümlülükleri iyi bir müdahale akışının doğal kilometre taşlarıdır. Senaryo: Saat 10:15, servis hesabında yetkisiz erişim; PLC konfigürasyonu değişmiş olabilir; makine çalışıyor; vardiya sorumlusu sizsiniz.

İlke: önce emniyet, hemen sonra kanıt. "Resetleyip devam edelim" yapılmaz; o düğme kanıtı siler.

Görev — zaman çizgisi

Aşama	Yanıt
1 · 10:15, ilk 15 dk	Aranacaklar: OT/IT güvenlik sorumlusu, bakım mühendisi (PLC), iş sağlığı ve güvenliği/safety sorumlusu, fabrika müdürü. İlk üç eylem: (1) Operatörleri kafa ve besleme alanından uzaklaştırıp makineyi kontrollü olarak güvenli durumda durdurmak; güç kesmeden, reset veya yeniden yükleme yapmadan. (2) Uzak erişimi kesmek (VPN/jump server oturumunu sonlandırmak, servis hesabını askıya almak), mümkünse segmenti izole etmek. (3) Olay günlüğünü başlatmak: saat, kim ne gördü, ne yapıldı.
2 · İlk 2 saat	Emniyet güvende mi? Yeniden başlatmadan önce Safety PLC program/konfigürasyon imzası bilinen iyi yedekle karşılaştırılır; E-stop, kapı kilidi, ışık perdesi ve durma süresi testleri yapılır. Korunacak kanıt: PLC ve Safety PLC mevcut konfigürasyon kopyası (geri yüklemeden önce), jump server/VPN/güvenlik duvarı logları, mühendislik istasyonu logları, ekran görüntüleri, hash değerleri. Kapatılacak hesap: ele geçirilen servis hesabı ve oturumları; paylaşılan parolalar yenilenir.
3 · 24 saat, CRA erken uyarı	Hazır bilgi: tespit zamanı, etkilenen makine/ürün ve sürümü, olayın kötü niyetli olduğuna dair şüphe, makinenin güvenli duruma alındığı, geçici önlemler, başka ürün/ülkeyi etkileme ihtimali. Bilgi eksik olsa bile ilk bildirim zamanında yapılır.
4 · 72 saat, CRA bildirim	Kök neden: hesap nasıl ele geçti (OT güvenlik, IT). Etki: safety fonksiyonu ve üretim etkisi (safety mühendisi, bakım). Önlem: hesap, MFA, erişim penceresi, konfigürasyon geri yükleme ve

	doğrulama (IT, bakım). Bildirim ve onay: uyum/hukuk ve fabrika müdürü.
5 · 14 gün, son rapor	Korunmuş olması gerekenler: VPN/jump server oturum kayıtları, kimlik doğrulama ve güvenlik duvarı logları, PLC/Safety PLC konfigürasyon sürümleri ve değişim geçmişi, mühendislik istasyonu logları, geri yükleme ve safety test kayıtları, olay günlüğü, kanıt saklama zinciri (kim, ne zaman, hash).

Not: 24 saat / 72 saat / 14 gün süreleri föydeki çerçevedir. Hangi bildirim yükümlülüğünün (CRA, NIS2, ürün üreticisi veya işletici rolü) şirketinize uygulandığını ve tam sürelerini hukuk/uyum biriminizle doğrulayın.

Bu föyün çıktısı Incident Workflow → Evidence Pack EP 13 Incident Response başlığına oturur.